HSLU Lucerne University of Applied Sciences and Arts

Product Security Lifecycle - Secure Development 1



SPREN
Alex Diekmann

Information Technology
September 25, 2026

FH Zentralschweiz

What you will learn

Part 1

- **Understand** the difference between **Product Cyber Security** and Information Security
- Know and **apply relevant** Laws, Regulations and **Standards** for specific target markets
- **Understand involved roles**

Part 2

- Understanding **Product Security Activities** and **Deliverables** within an SDLC

Part 3

- **Build and integrate an SDLC** for Product Security purpose based on relevant standards
- **Explain** to Management and Developers **why** Product Security is essential

Deep Dives

- **Security Architecture & Design** in context of IEC 62443
- How to do **Product Security Risk Management**
- How to ensure **Supply Chain Security**

Other lectures

- ➢ **SPRG**
- Microsoft SDL
- Threat Modeling with STRIDE / DREAD
- Requirements Management

- ➢ **IoT Security**
- ➢ **Cloud Security**
- ➢ **Information Security Fundamentals**

HSLU Lucerne University of Applied Sciences and Arts

Why Product Cybersecurity?

Drivers & Comparison to Information Security

Information Technology
September 25, 2026

FH Zentralschweiz

This is a product…







Windows

Word





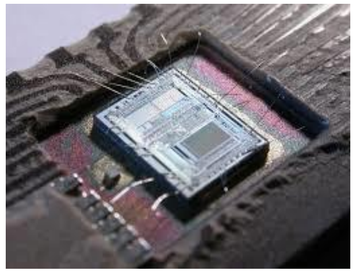


This is also a product!











➢ They all need Product Cybersecurity!

Product Security gone wrong

CYBERWARFARE

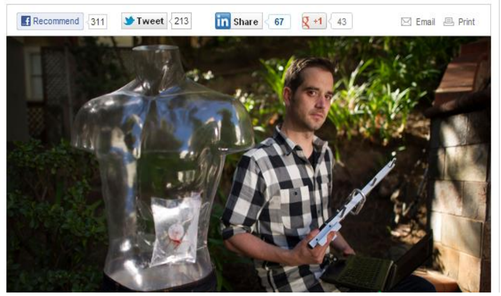
Dutch Engineer Used Water Pump to Get Billion-Dollar Stuxnet Malware Into Iranian Nuclear Facility: Report

An engineer recruited by intelligence services reportedly used a water pump to deliver Stuxnet, which reportedly cost $1-2 billion to develop.

2010: Stuxnet-infected USB drive breaks SCADA controllers to DoS Iranian Uranium Centrifuges – Kickstarting Security for Critical Infrastructure (SecurityWeek, 2024)

Hacker Shows Off Lethal Attack By Controlling Wireless Medical Device

BY JORDAN ROBERTSON | FEB. 29, 2012 10:10 AM EDT | POSTED IN POSTS, SECURITY, VIDEO | 10 COMMENTS



2012: Medronic Insulin Pump hacked by Barneby Jack, remote kill possible – kickstarting Medical Device Security

Hack In The Box: researcher reveals ease of Huawei router access

At Hack In The Box researcher Felix "FX" Lindner has shown how Huawei routers are easy to access with their static passwords and how one machine could give an attacker access to an entire network.

2012: Huawei Routers hacked by FX (Recurity Labs), starting the large wave of router hacks and increasing focus on IoT device security

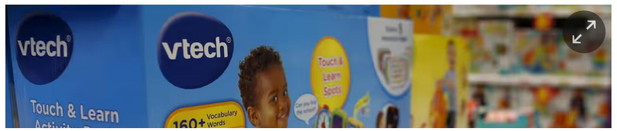
Hackers Remotely Kill a Jeep on the Highway—With Me in It

I was driving 70 mph on the edge of downtown St. Louis when the exploit began to take hold.

2015: Jeep hacked through backend system enables remote control of the car, kickstarting Automotive Cybersecurity

Toy firm VTech hack exposes private data of parents and children

Company admits breach and suspends trading on Hong Kong stock exchange, while security experts criticise poor security and lack of encryption



2015: Toymaker VTech hacked, leaking 4.6 million records of parents **and children**, showing the risks of insecure consumer IoT

The story of the great Polish train hack

Polish rolling stock company Newag has alleged its train systems were illegally hacked, making four of its trains unsafe.

2023: Hacker uncover planned obsolescence of Newag trains, getting sued. Shows some companies still havn't learned the lesson

Product Security still going wrong

Hacking Attack Leaves Russian Car Owners Locked Out of Their Vehicles

2026: Cyberattack on Alarm System provider bricks Porsches throughout Russia (Fortra, 2026)

AI-Assisted Threat Actor Compromises 600+ FortiGate Devices in 55 Countries

2026: Misconfigured FortiGate firewalls found and hacked via LLM-assistance (Hackernews, 2026)

Cyber Attack on Jaguar Land Rover: £1.9 Billion Impact and Key Lessons on Supply Chain Security

2025: JLR hacked via unpatched SAP Netweaver Vulnerability, causing monthlong outage (Mastodon Security, 2025)

MOVEit Breach: Timeline of the Largest Hack of 2023

2023: SQL Injection vulnerability in file transfer software abused to hack over 2000 organizations (Hadrian, n.d.)

Widespread Data Theft Targets Salesforce Instances via Salesloft Drift

2025: Salesforce instances hacked via stolen OAuth tokens from vulnerable AI chatbot integration (Google & Mandiant, 2025)

Cyber Espionage Campaign Exploits Claude Code Tool to Infiltrate Global Targets

2025: Claude Code jailbroken by Chinese attackers to compromise 30 global organizations (Campus Technology, 2025)

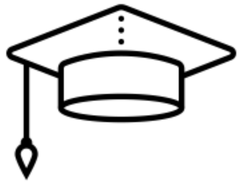
Why Product Security goes wrong



Product Cyber Security vs. Information Security

	Product Cyber Security	Information Security
Scope	• **Physical Products** sold to customers • Mass-deployed **Software Products** • **Cloud Services** provided to customers	• **Corporate IT** Infrastructure • **Network** Infrastructure, Servers & Clients • **Corporate Cloud** Infrastructure
Challenges	• Very short (IoT) to **very long (OT) lifecycle** • **Difficult access** to live systems • Manufacturer <> **Customer relationship** • **Diverse technology** and architecture • Different **target markets** with different requirements	• **Awareness & Governance** • **Inventory** of assets • Security **Monitoring** • **Legacy** Infrastructure • **Complex** Enterprise Architecture (on-prem & Cloud)
Focus Areas	• **SDL** • Secure Coding • White-box Security Testing • System **Hardening** • System **Architecture** • **Vulnerability Management**	• **IAM** • Network Security • **Policies & Standards** • Enterprise Architecture • Vulnerability Scanning & Patching • **Incident Detection & Response**

Quiz



1. What’s the biggest challenge in OT Security?

a) Security Monitoring

b) Long Product Lifecycle

c) Pathing

d) Customer Satisfaction

2. What’s not a driver for nation states to create Cybersecurity laws?

a) Growing number of vulnerabilities

b) IoT Security Incidents

c) Cost Savings

d) Cyberwar

3. Which of the following product types does not need Cybersecurity?

a) Plane

b) Smart Watch

c) Kitchen Knife

d) Smart Fridge

HSLU Lucerne University of Applied Sciences and Arts

What to achieve?

Product Cybersecurity Goals, Laws, Regulations & Standards

Information Technology
September 25, 2026

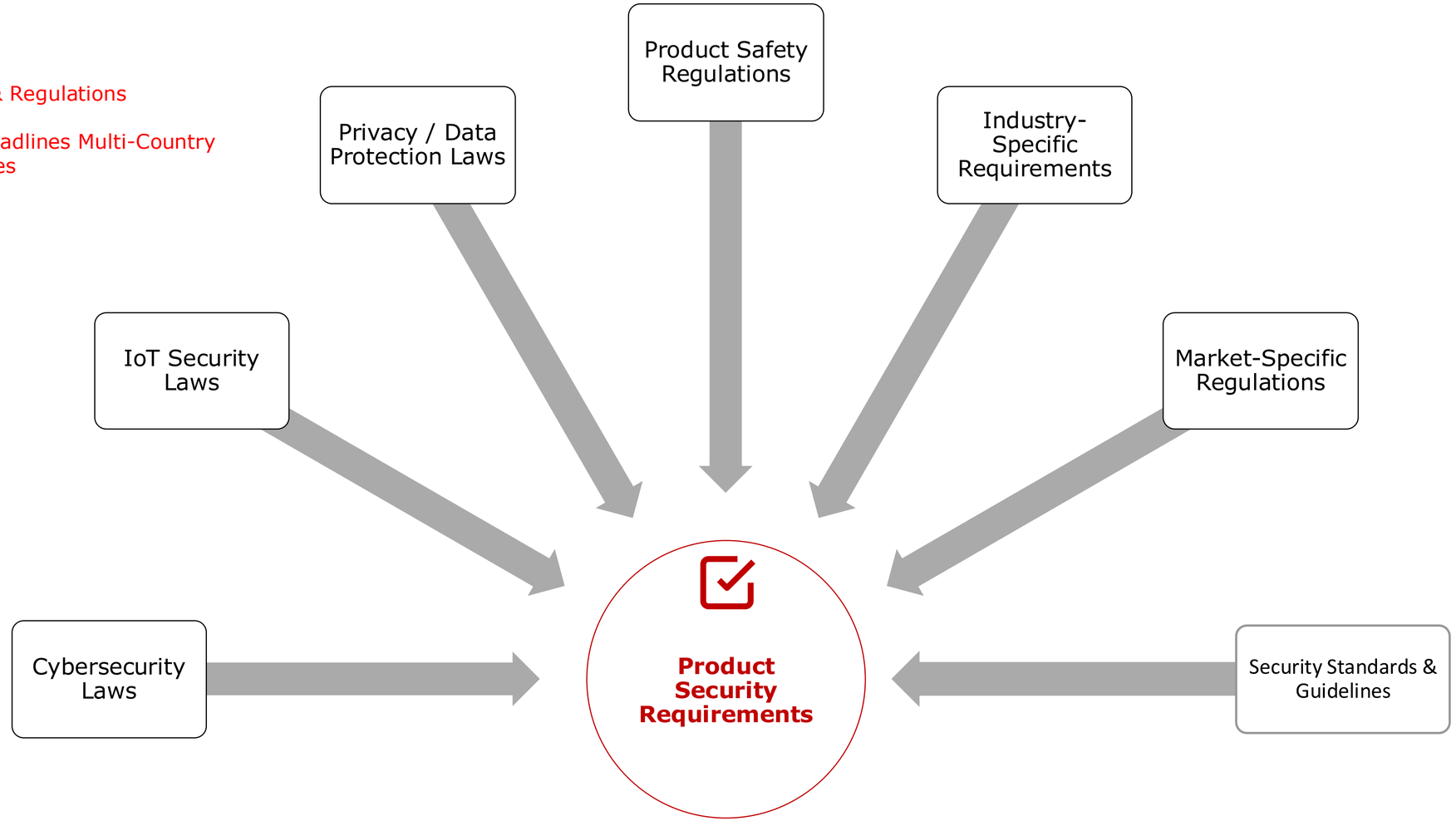
FH Zentralschweiz

Product Cybersecurity Goals



Sources of Product Security Requirements

Challenges
- Conflicting Laws & Regulations
- Data Residency
- Tight reporting deadlines Multi-Country
- Different languages



Security Laws emerge globally

EU
- **Cyber Resilience Act**
- Cybersecurity Act
- NIS2 Directive
- Data Law
- Radio Equipment Directive (RED) 3.3 d) e) f)
- MDR / IVDR
- GDPR
- AI Act

...

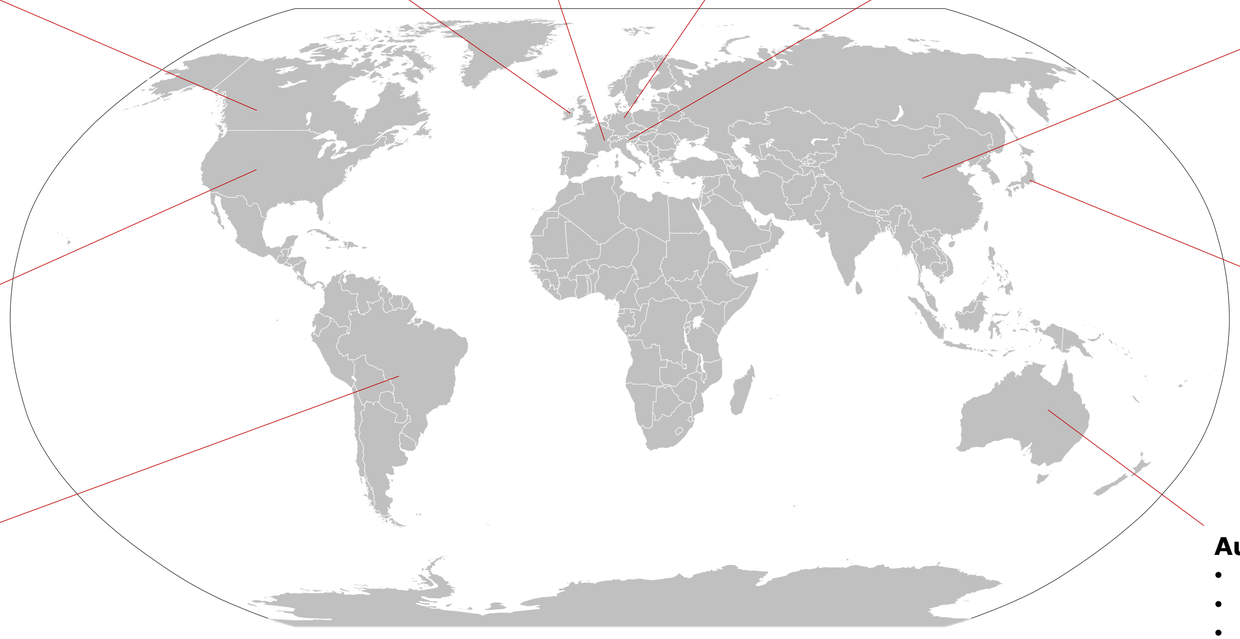
Germany
- KRITIS
- IT Sicherheitsgesetz 2.0

UK
- PSTI

Switzerland
- ISG
- (DSG)

Canada
- CCSPA
- PIPEDA

China
- Cybersecurity Law (CSL)
- Data Security Law (DSL)
- Personal Information Protection Law (PIPL)
- Security Standards (GBs)



U.S.A.
- Cybersecurity Improvement Act
- California SB-327, CPRA, CCPA
- Oregon HB 2395
- Sarbanes-Oxley (SOX)
- PCI-DSS
- Gramm-Leach-Bliley Act (GLBA)
- FDA Cybersecurity Guidance
- (HIIPA / HITECH)
- 15 CFR 791 / VCS rule

...

Japan
- IoT Security & Safety Framework

Brazil
- ANATEL Act'77

Australia
- Cybersecurity Act
- Security Standards for Smart Devices
- Security of Critical Infrastructure Act (SOCI)

Global
- UN R155 Automotive Cybersecurity
- ICAO A41-19 Addressing Cybersecurity in Civil Aviation

& many more...

EU Cyber Resilience Act (EU 2024/2847)

Scope

Applies to all "Products with Digital Elements" sold in EU

- *(except otherwise regulated fields, e.g. Medical, Automotive, Rail, Aviation…)*
- Includes connected "Backend Servers" (i.e. remote update solution, connected cloud services)
- Supplements other directives (e.g. RED 3.3, AI Act, NIS2)

Product classes

1. **Default** (General IoT devices)
2. **Important Class I** (e.g. routers, PW managers)
3. **Important Class II** (e.g. Firewalls, hypervisors)
4. **Critical** (e.g. Smart Cards, Secure Elements)

Key Requirements to manufacturers

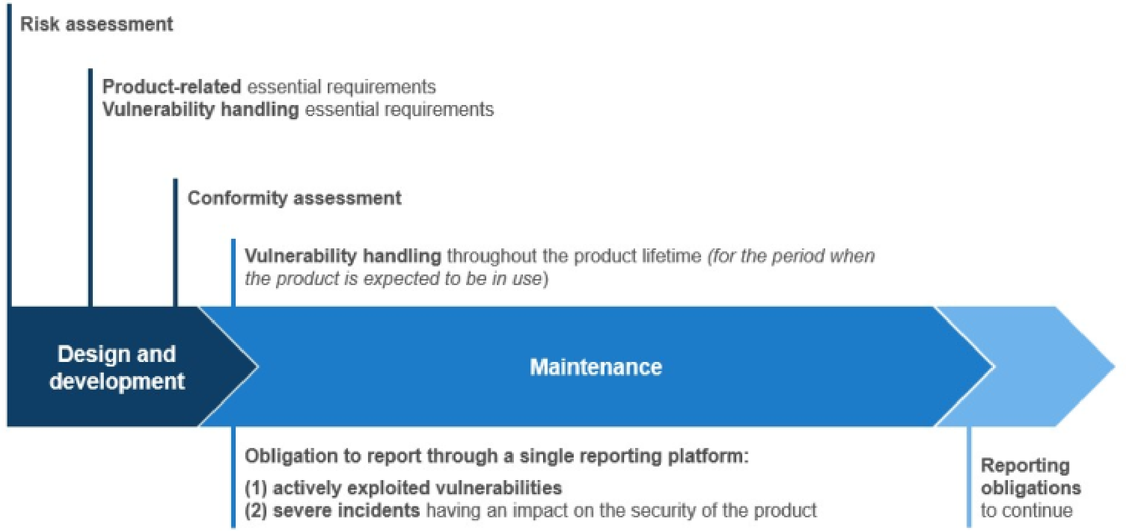
- **Risk-based** approach to product security
- Products released "without known exploitable vulnerabilities"
- Secure by Design & Secure by Default
- Security Testing, Vulnerability Management & min. 5 years security patching for free after EoL
- Reporting of Actively Exploited Vulnerabilities within 24h to ENISA and local authorities

Conformity assessment / CE Marking

- Key activity: **Justify why essential requirements are fulfilled**
- Default: Self assessment & declaration
- Important Class I: Self assessment according to harmonized standard (e.g. IEC 62443) or 3rd party assessment
- Important Class II & Critical: 3rd party assessment & certification by notified body

EU Cyber Resilience Act (EU 2024/2847) – Implementation

Certification Process



Resources

- Official EU F.A.Q.
- CRA for Manufacturers
- Self Assessment Tool

Timeline

- ➢ Effective since 11.Sept.2026:
  Mandatory Incident & AEV reporting
- ➢ From 11.Dec.2027 - All requirements effective

Standards

- **41 Harmonized Standards (in development)**
- **Horizontal Standards (EN40000-1)**
  - Vocabulary (EN40000-1-1)
  - Principles (EN40000-1-2)
  - Vulnerability handling (EN 40000-1-3)
  - Generic Security Requirements (EN40000-1-4)
- **Vertical Standards**
  - Network components (routers, switches, firewalls, VPN systems)
  - Software products (browsers, password managers, operating systems, hypervisors)
  - Smart-home and consumer products (smart locks, cameras, wearables, toys)
  - Industrial components (microcontrollers, ASICs, FPGAs, smart meter gateways)
  - Security components (hardware security modules, smartcards, secure elements)

Standards Overview (excerpt)

Process Standards

- **Common Criteria Part 3 (ISO 15408-3)**
- **ISO 21434 Automotive CSMS**
- **IEC 62443-4-1 IACS Component Security Processes**
- ISO 81001-5-1 Health IT Security Lifecycle
- CLC/TS 50701 Railway Cybersecurity
- NIST Cybersecurity Framework
- **Microsoft SDL**
- OWASP SAMM

…

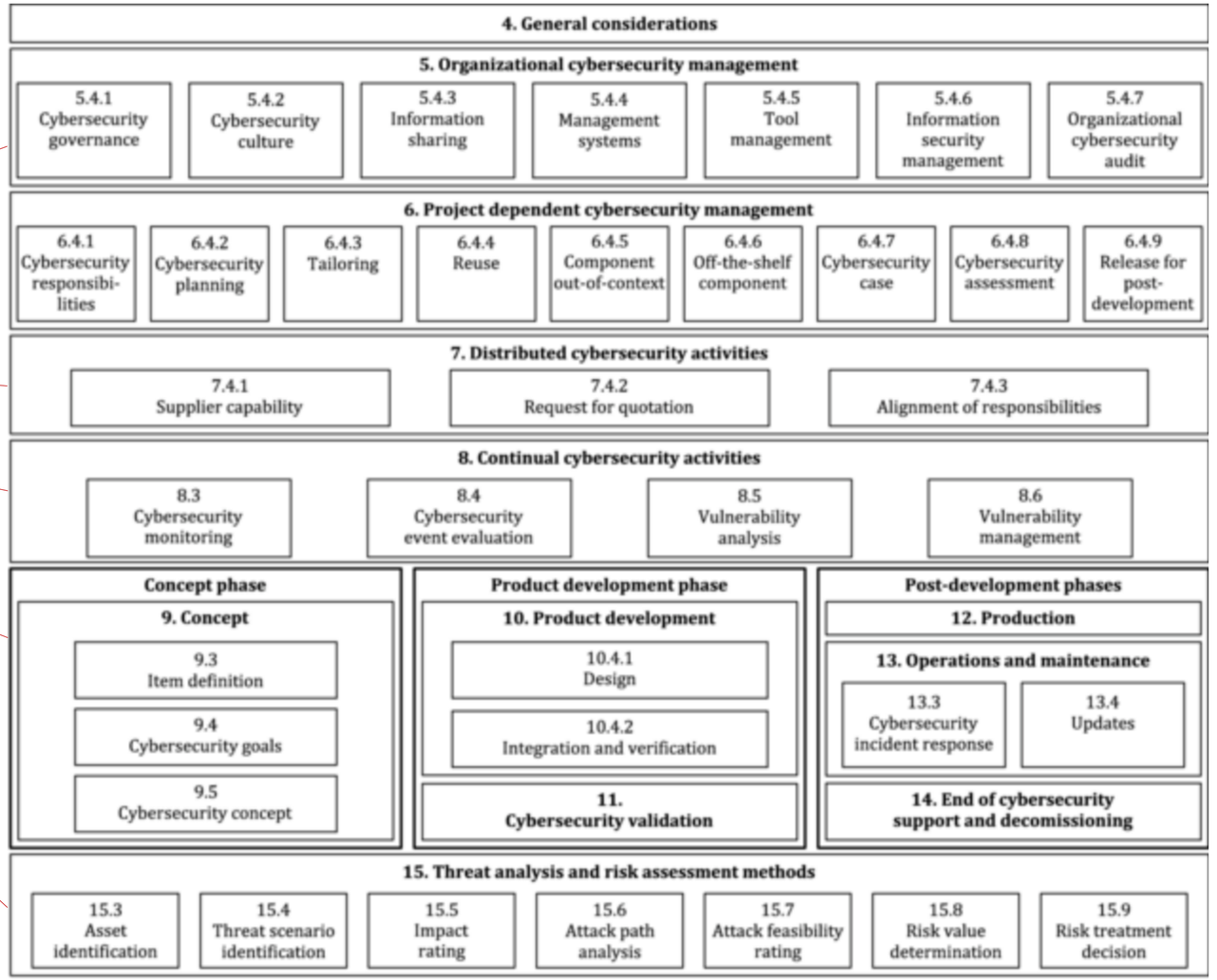
Control Standards & Hybrids

- **Common Criteria Part 2 (ISO 15408-2)**
- **EN 18031 Cybersecurity Testing for Radio Equipment**
- **IEC 62443-4-2 IACS Component Security Measures**
- **EN 18031- Radio Equipment Cybersecurity**
- ETSI EN 303 645 Cybersecurity for Consumer IoT
- FIPS 140-2/-3
- CSA Cloud Control Matrix
- ISO27400 Guideline IoT Security Controls
- NIST SP800 Series
- ISO 24882 Agriculture Product Cybersecurity (Draft for comment)

…

ISO 21434

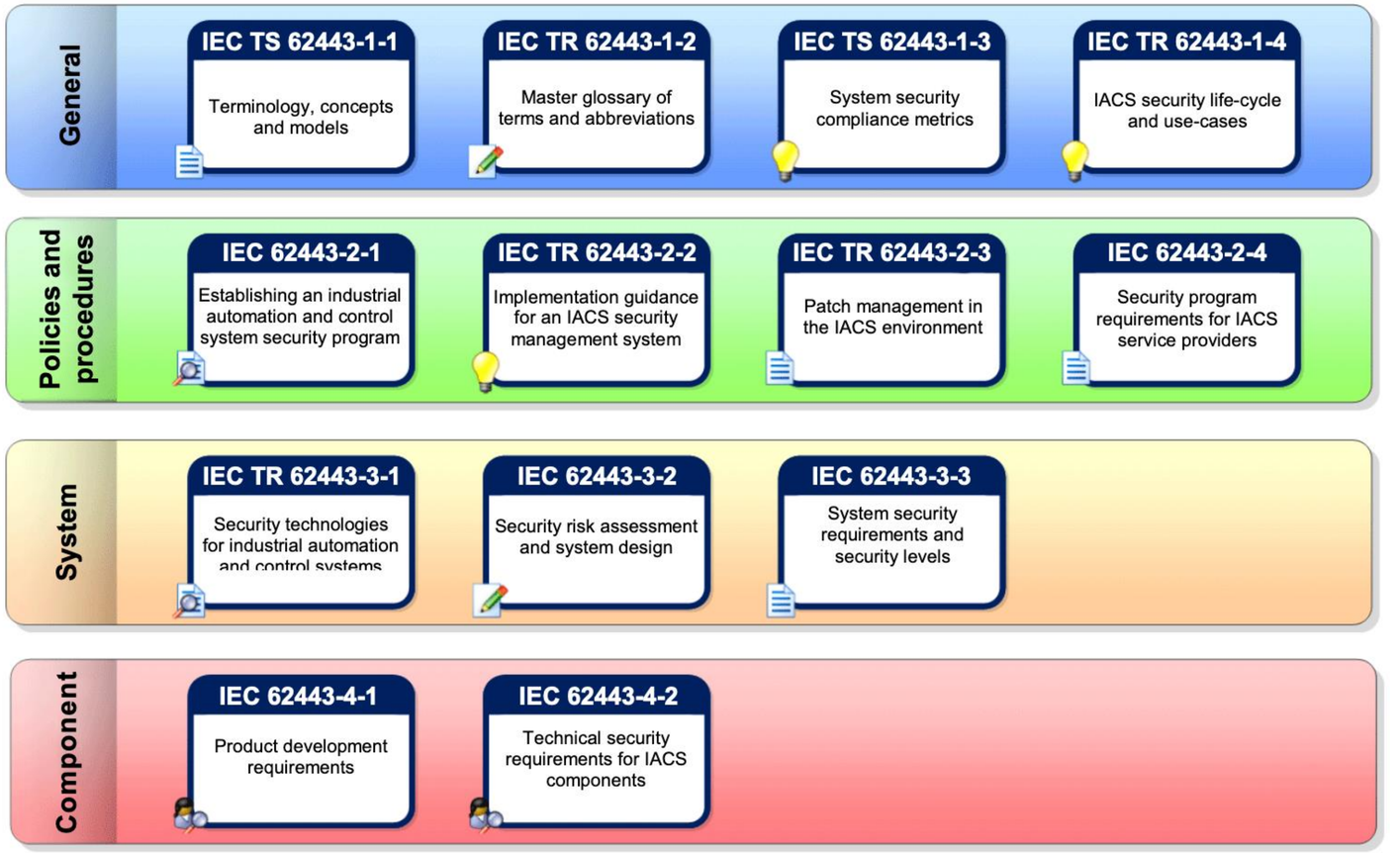
- Driven by UN R155 >Mandatory for Automotive Component Suppliers
- Management System & Development Security requirements
- Propagates down the Supply Chain
- Strong Vulnerability Management focus
- Secure Development Processes with customer-facing work products
- Detailed requirements for Threat Modeling & Risk Assessment



iso.org - ISO/SAE 21434 Preview

ISO 62443 Series – Security

- Designed for Industrial Automation and Control Systems (IACS)
- Also referred to from other fields:
  - Railwail (CLC/TS 50701)
  - Medical (FDA CS Guideline, MDR / IVDR)
  - Aviation (IATA Guidelines)
- Sub-Standards for
  - System Integrators & Operators
  - **Product Developers**

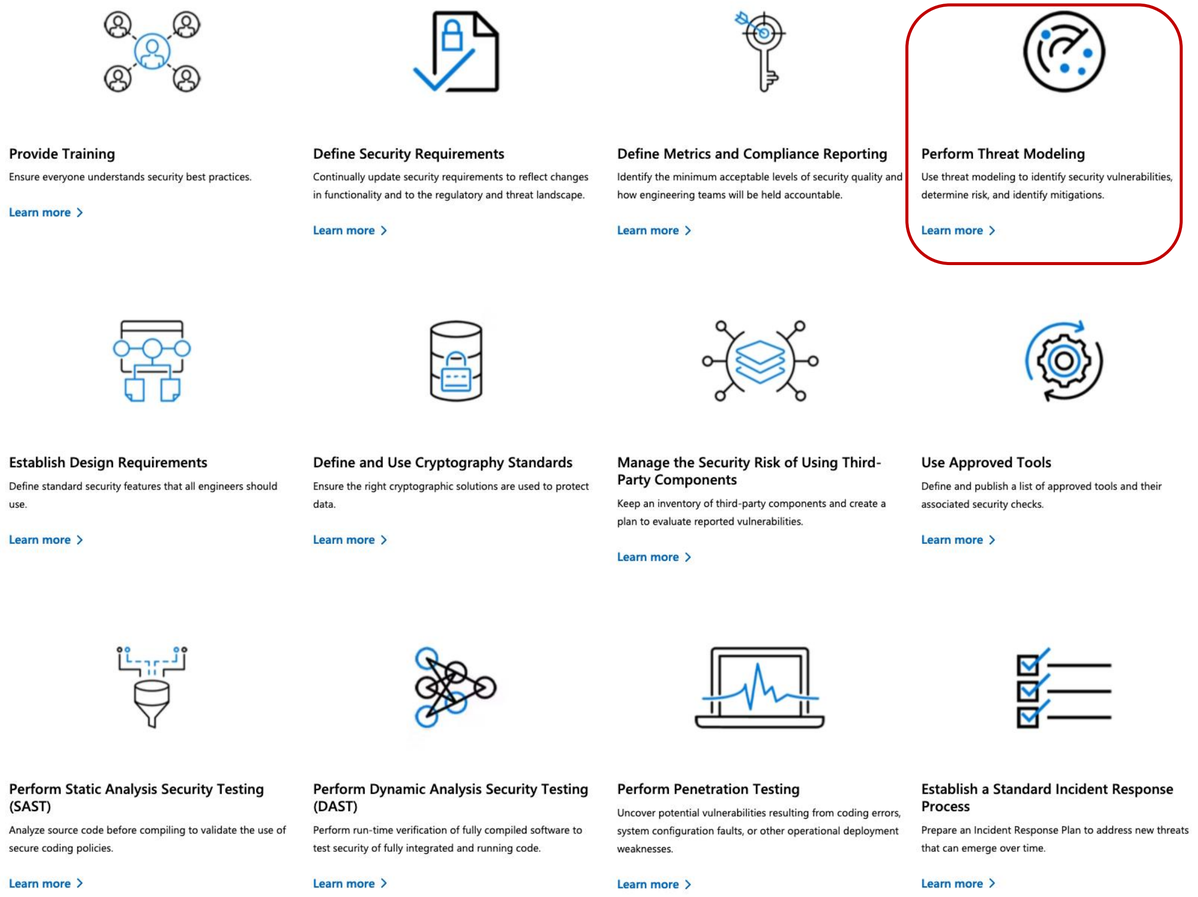


https://webstore.iec.ch/preview/info_iec62443-4-1%7Bed1.0%7Den.pdf

Recap: MS Secure Development Lifecycle

- Established and implemented by MS in 2004
- 12 Practices to improve security of Microsoft products
- Threat Modeling as core practice
- Supported by a suite of tools

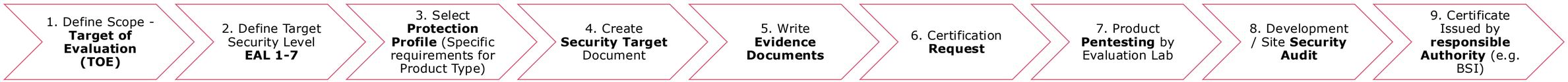




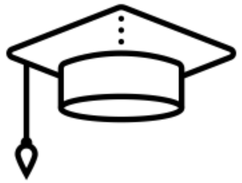
Common Criteria ISO15408

- Generic Security Certification scheme for IT products (Software & Hardware)
- Covers both **Product Security** and **Development Security**
- Often used for Smart Cards, HSMs / Secure Elements and other **security devices & software**
- Typically required for military applications

- ISO 15408-1 – **Terms & Concepts**
- ISO 15408-2 – **Functional Requirements**
- ISO 15408-3 - **Assurance Requirements**
- JIL MSSR - **Minimum Site Security Requirements** – Development (& Manufacturing) Security System (DSMS) based on ISO27001
- ISO 18045 CEM – **Evaluation Methodology**



Time to rest



10 Min Break

HSLU Lucerne University of Applied Sciences and Arts

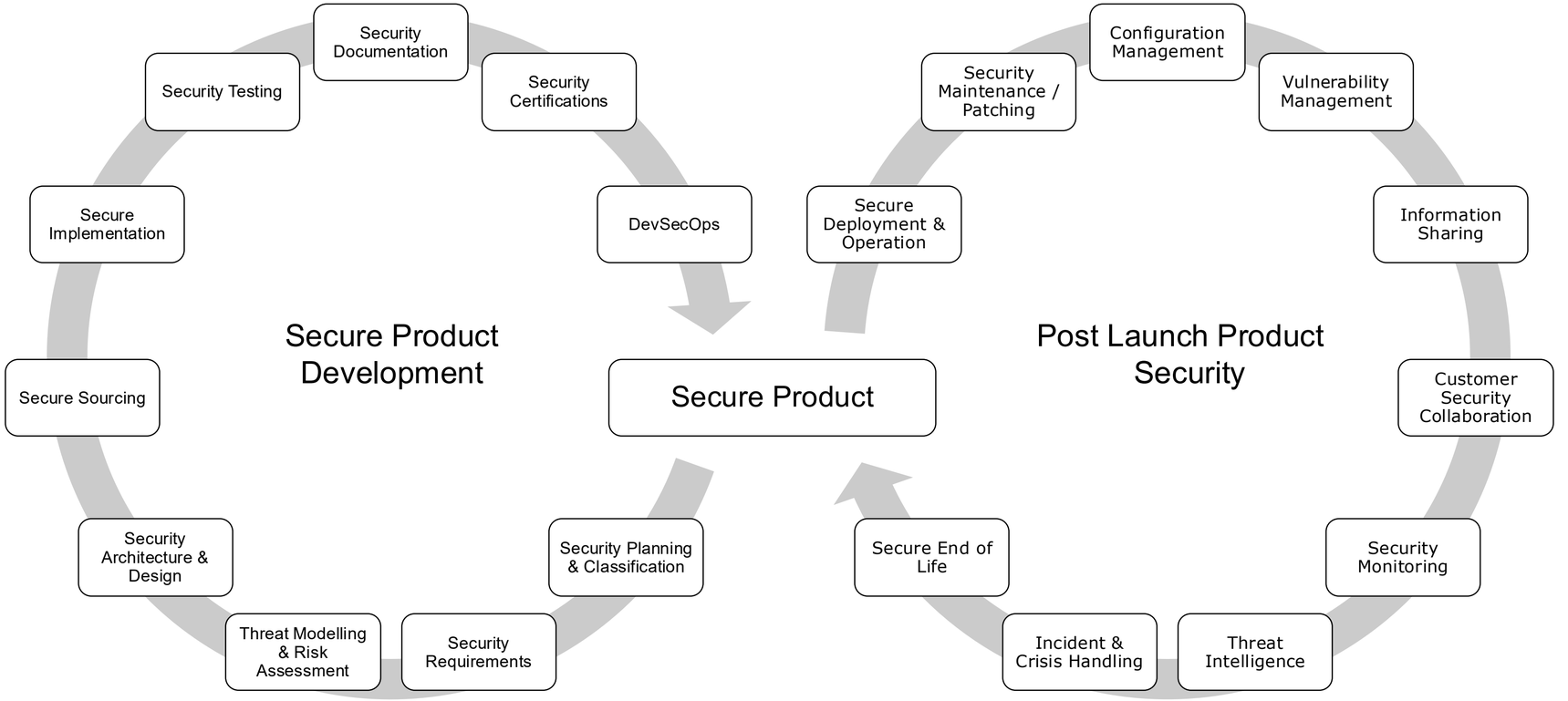
What to do?

The Product Security Lifecycle

Information Technology
September 25, 2026

FH Zentralschweiz

Product Cybersecurity Lifecycle



Cyber Security Management System(s)

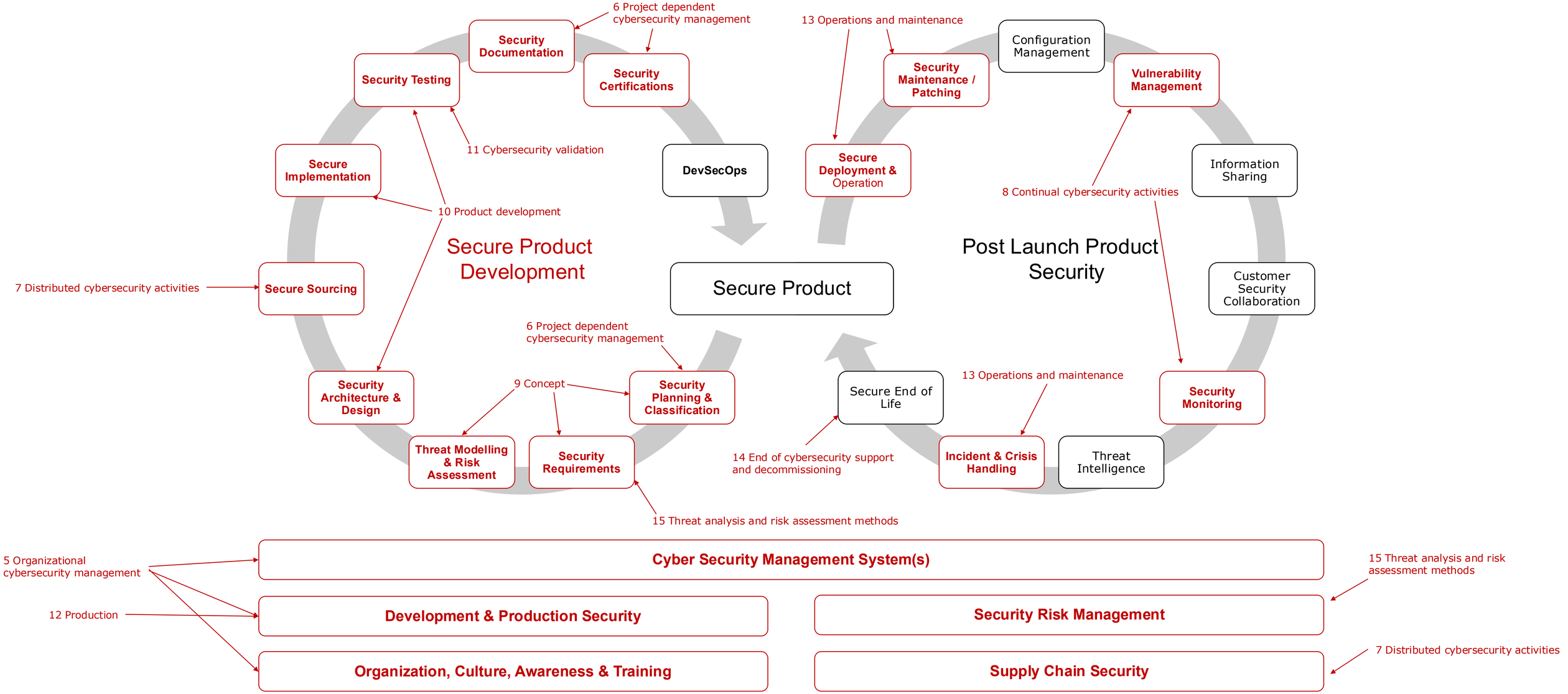
Development & Production Security

Security Risk Management

Organization, Culture, Awareness & Training

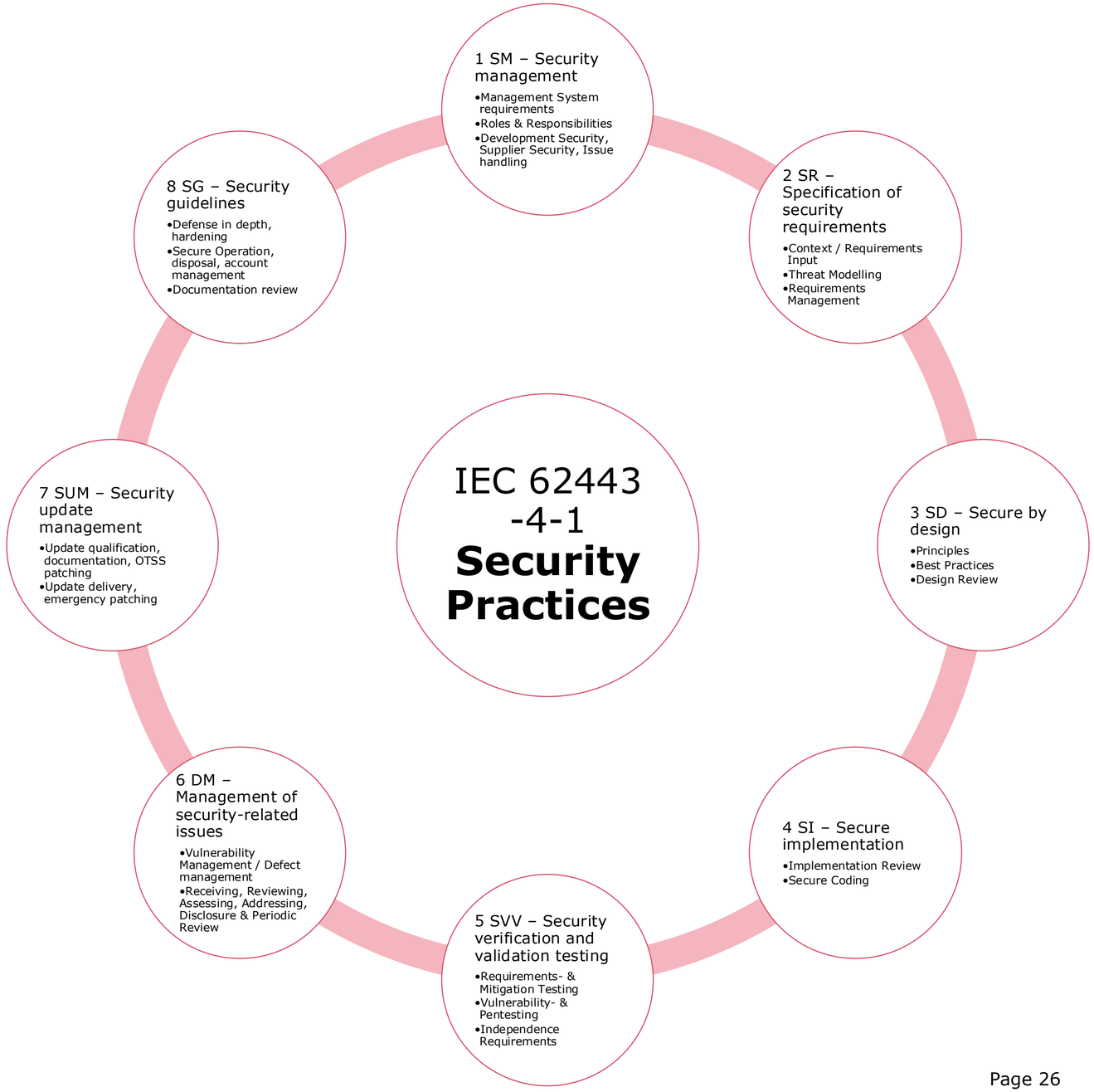
Supply Chain Security

Product Cybersecurity Lifecycle – mapped to ISO 21434

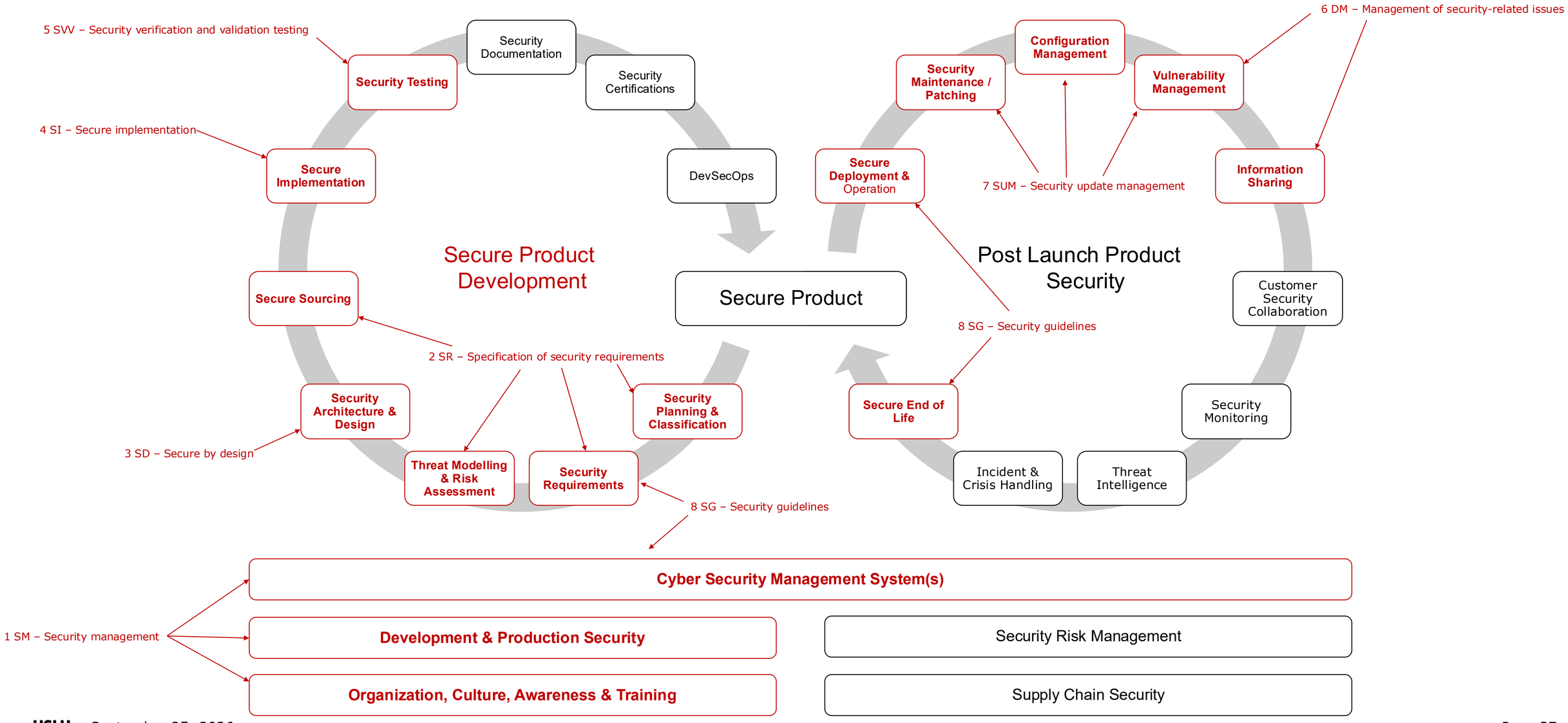


ISO 62443-4-1

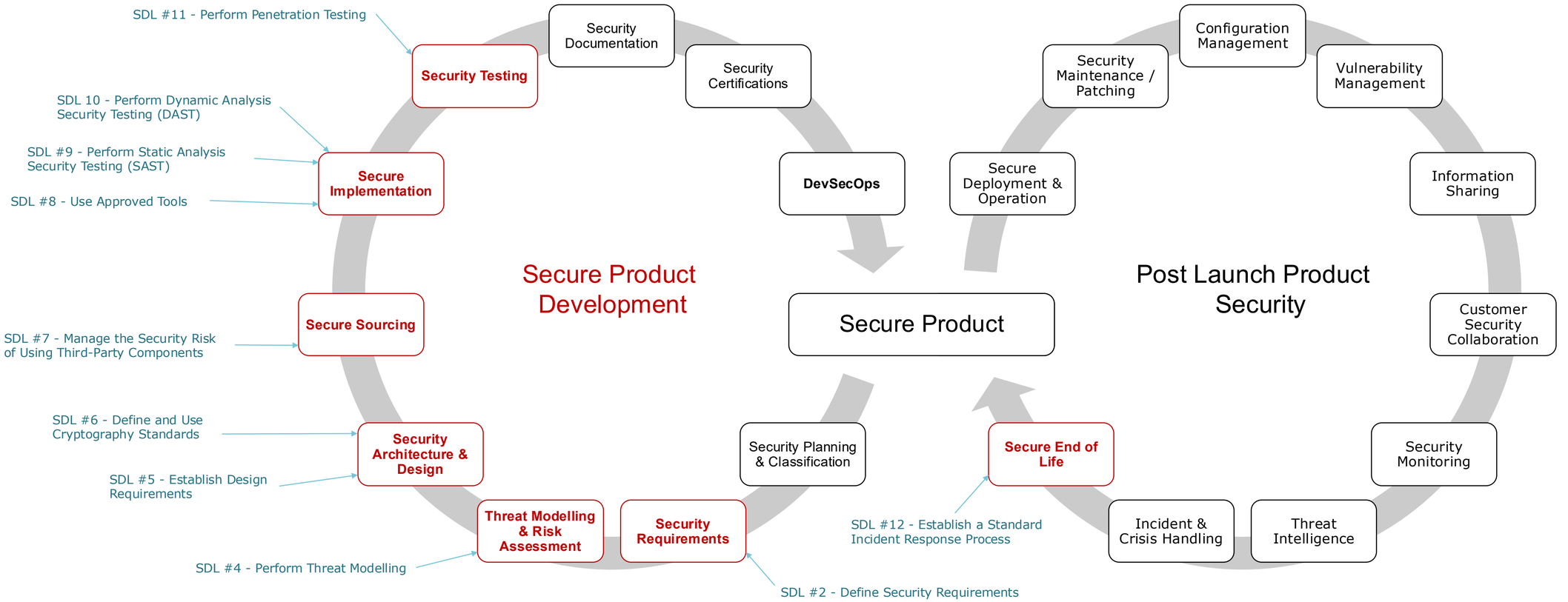
- Practices for Secure Development & Maintenance of IACS Products
- Covers
  - Pre- & Post Launch Product Security
  - Development Security
  - Credential Management
- CMMI-based Maturity Levels 1-4 per practice
- Classification concept “Security Level” 1-5 to tailor controls
- ➢ **More in lecture “Security Architecture & Design”**



Product Cybersecurity Lifecycle – mapped to IEC 62443-4-1



Product Cybersecurity Lifecycle - MS SDL extended



SDL #3 - Define Metrics and Compliance Reporting

Cyber Security Management System(s)

Development & Production Security

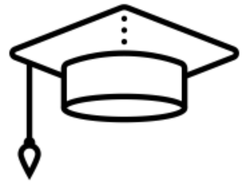
Security Risk Management

SDL #1 - Provide Training

Organization, Culture, Awareness & Training

Supply Chain Security

Quiz



1. What’s the strongest driver for Product Cybersecurity?

a) Vulnerabilities & Incidents

b) Laws & Regulations

c) Security Standards

d) Customer Satisfaction

2. Which of the following markets does not recognize IEC 62443?

a) Railway

b) Medical

c) Automotive

d) Industrial

3. Which of the following is not a source for security requirements?

a) Data Protection Laws

b) Product Safety Laws

c) Public Trade Laws

d) Tax Laws

HSLU Lucerne University of Applied Sciences and Arts

Who does it?

Product Security Organization & Stakeholders

Information Technology
September 25, 2026

FH Zentralschweiz

Product Security Expert – Job profile

Hard Skills

- Cybersecurity
- System Engineering
- IT Architecture
- Software Development
- Auditing
- Process Management

Soft Skills

- Resillient
- Organized
- Persuasive
- Persistent
- Good Communicator
- Team-player
- Dilligent

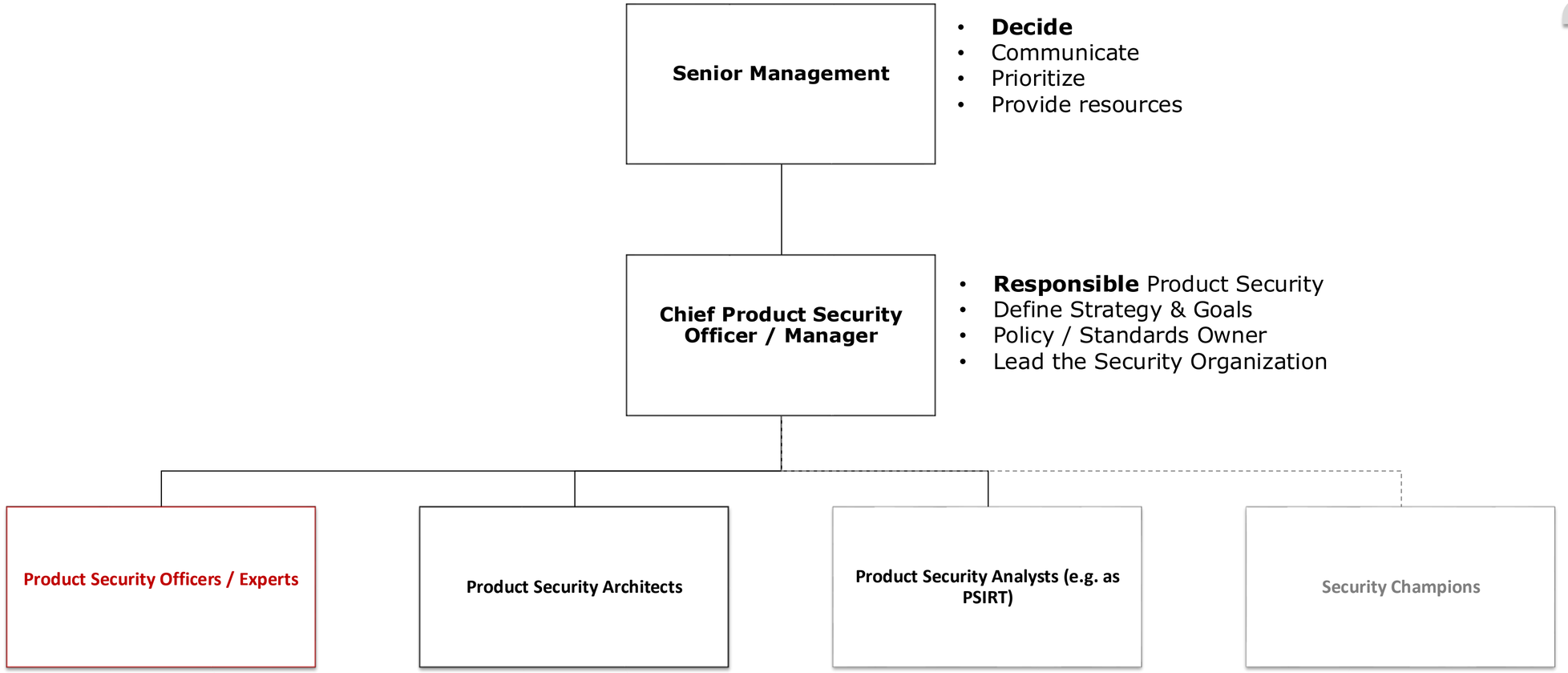
Challenges to overcome

- Complexity drives vulnerability
- Resistance from product management
- Management pressure for faster and cheaper
- Time pressure
- Compliance requirements growing
- Growing customer demand

➢ **Nobody’s perfect**

Product Security Organization – Pre-launch Responsibilities





- **Decide**
- Communicate
- Prioritize
- Provide resources

- **Responsible** Product Security
- Define Strategy & Goals
- Policy / Standards Owner
- Lead the Security Organization

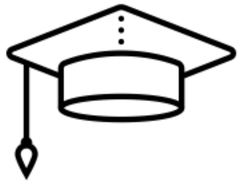
- Define Policies & Standards
- Conduct **Risk Assessments**
- Support Audits & Reviews
- Support Development Projects
- Support Issue Handling

- Define Security Architectures
- Support Security Design
- Conduct **Architecture** Reviews

- **Vulnerability & Incident Handling**
- Vulnerability Monitoring / Threat Intelligence
- Responsible Disclosure
- Information Sharing
- Customer Sec. Support
- Security Testing

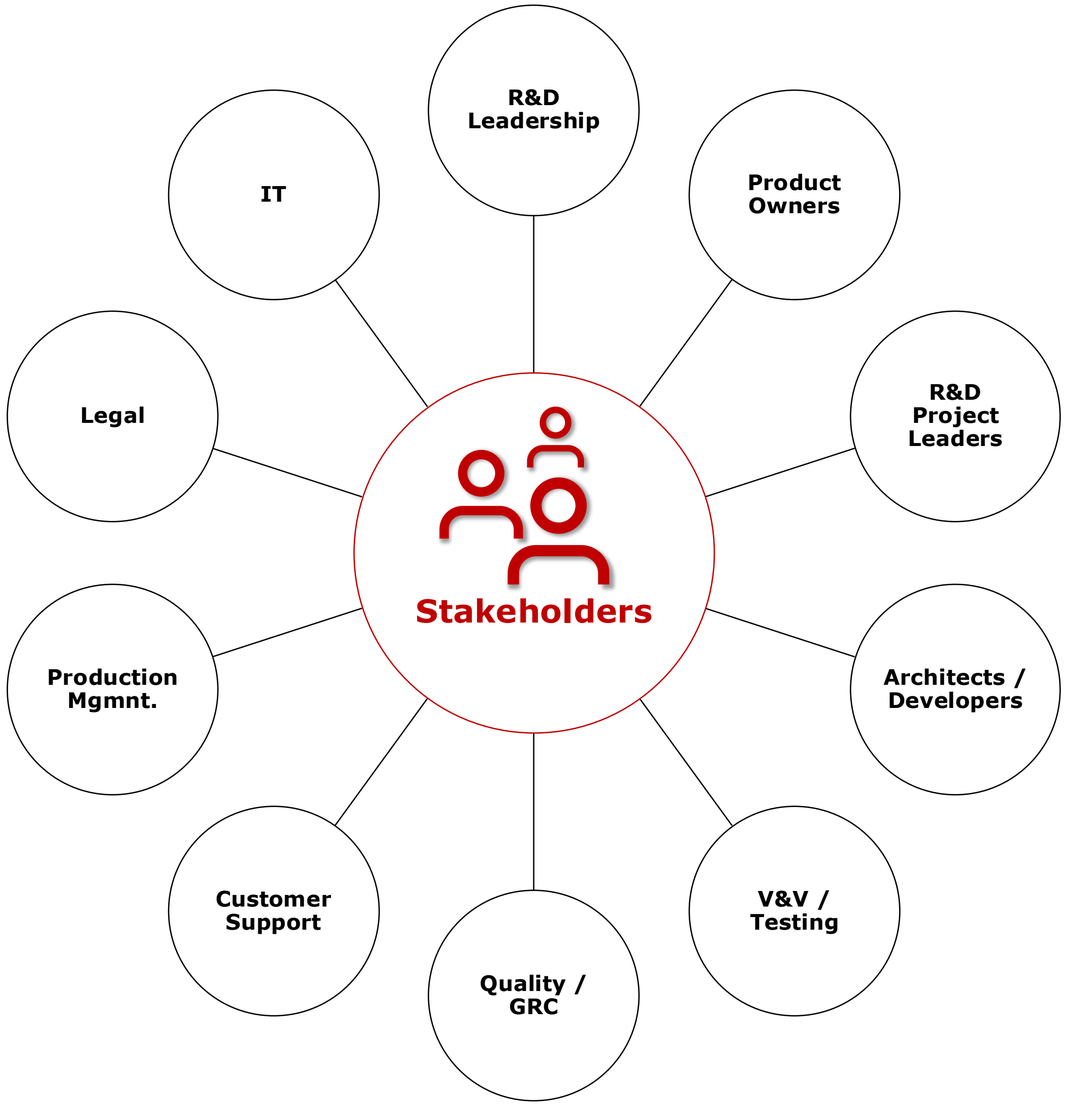
- Apply and spread security know how **within R&D / business teams**
- Lead implementation of security features
- E.g. Security-aware developers / architects

Exercise



Which **stakeholders** in a typical organization need to be involved regarding **Product Security**, and for **what**?

Who? – Stakeholders



HSLU Lucerne University of Applied Sciences and Arts

Case Study

Applicable Laws, Regulations & Standards?

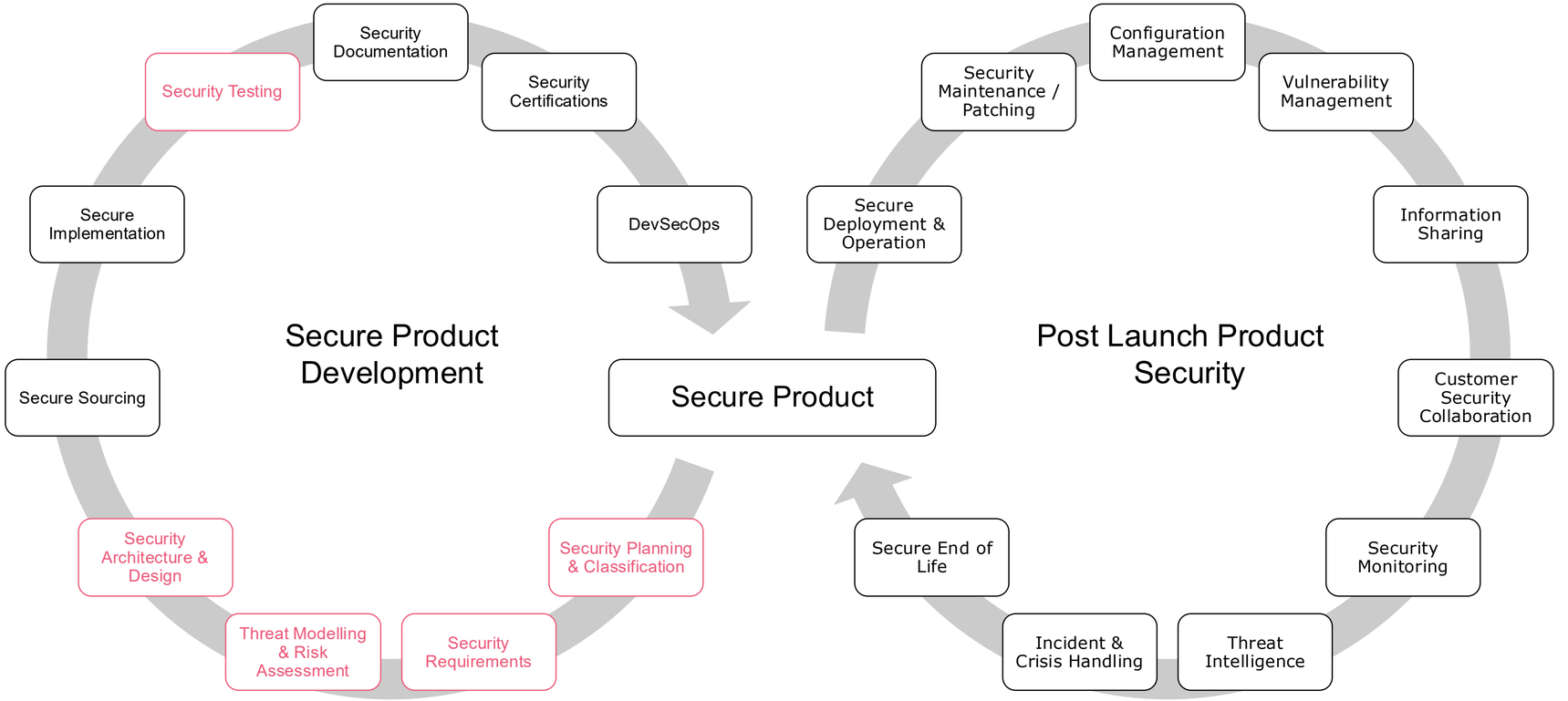
Information Technology
September 25, 2026

FH Zentralschweiz

Your Project for this Term

Deliverables

Cybersecurity Plan



Cyber Security Management System(s)

Development & Production Security

Security Risk Management

Organization, Culture, Awareness & Training

Supply Chain Security

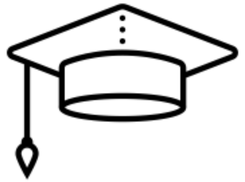
Homework in Groups

- Anayze your chosen case study. Identify product use cases, geographic target markets and target industries / segments. List them in your Cybersecurity Plan and describe briefly why they apply, and what part of them does.
- What Laws, Regulations and Standards apply to your products? List identified standards, decide whether they are mandatory or optional, provide a brief justification.
- Assuming you sell to the EU, does the Cyber Resilience Act apply to your product? Provide a justification in the Excel. What category does your product fall into?
- Use AI to research. Read the sources!
  Don’t use AI to reason for you! Write the justifications by yourselves!

➢ Use the provided **Cybersecurity Plan Template**

➢ **See live walkthrough**

Time for questions





Contact Details



Alex Diekmann

e-Mail: alexander.diekmann@hslu.ch

Threema: 7SBWM9V7

LinkedIn: https://www.linkedin.com/in/alexdiekmann/

Contents of these slides may not be modified or re-used without prior approval of the author.

This presentation includes icons from the feather framework, which is published under the MIT license, and (where other sources are not specified) uses images from Wikimedia, released under Creative Commons 2.0 License or as Public Domain